

Email privacy

Your email inbox is one of the most sensitive data stores in your digital life - it contains years of financial records, medical correspondence, account confirmations, and private conversations. This guide covers switching to a private provider, masking your address, and keeping your inbox clean.

CHOOSE A PRIVATE EMAIL PROVIDER

Switch to ProtonMail for sensitive communications

CRITICAL

`mail.proton.me`

Why it matters: ProtonMail uses end-to-end encryption for emails between ProtonMail users - even Proton cannot read them. It's based in Switzerland under strong privacy laws, has never complied with a request to hand over message content (only metadata under court order), and is open source with published independent audits. The free tier is generous enough for most people.

Steps:

1. Create a free account at `mail.proton.me` - choose a username that doesn't identify you
2. Set a strong passphrase for your account and store it in your password manager
3. Enable two-factor authentication immediately: **Settings** → **Account and password** → **Two-factor authentication**
4. Set up an account recovery method - either a recovery email address (can be another ProtonMail) or a recovery phrase. Store the recovery phrase in your password manager
5. Download the ProtonMail app on your phone for mobile access

Evaluate other private email providers

CRITICAL

Various - see options

Why it matters: ProtonMail is the best-known option but not the only strong choice. Different providers offer different tradeoffs around price, features, and jurisdiction - the right choice depends on your threat model.

Steps:

1. **Tutanota** (now Tuta) - German-based, end-to-end encrypted, open source, free tier available. More aggressive on encryption than Proton (encrypts subject lines too). Good Proton alternative at `tuta.com`
 2. **Startmail** - Netherlands-based, PGP encryption, supports custom domains and aliases. Focused purely on email privacy at `startmail.com`
 3. **Fastmail** - Australian-based, strong privacy practices but not E2EE by default. Best if you need maximum compatibility and custom domains over zero-knowledge encryption
 4. Avoid: Gmail, Yahoo Mail, Outlook/Hotmail for sensitive communications - all scan email content and comply with US law enforcement requests with no end-to-end encryption
-

Set up a custom domain for long-term email independence

HIGH

Your email provider → Settings → Custom domains

Why it matters: If you use a @proton.me or @gmail.com address and ever want to switch providers, you have to update every account you've signed up to. A custom domain (e.g. yourname.com) means you own the address permanently - switch providers freely without breaking any logins.

Steps:

1. Purchase a domain from a privacy-respecting registrar - **Porkbun** and **Njalla** are good options. Avoid GoDaddy
 2. In ProtonMail: **Settings** → **Identity and addresses** → **Add address** → **Add domain**
 3. Follow the DNS verification steps - your domain registrar will have a DNS settings panel where you add the records Proton provides
 4. Once set up, use **you@yourdomain.com** as your primary address going forward
 5. Note: Proton's custom domain feature requires a paid plan (~\$4/month)
-

MIGRATE AWAY FROM GMAIL OR OUTLOOK

Plan your migration before you start

CRITICAL

Applies before switching providers

Why it matters: Switching email providers without a plan can lock you out of critical accounts. Approaching it methodically - high-priority accounts first, then bulk updates - makes the transition smooth and safe.

Steps:

1. Search your current inbox for **verify**, **confirm your email**, and **welcome** to inventory every account tied to your old address
2. Categorize accounts into three tiers - Critical (banking, insurance, Apple/Google, password manager, government), Important (shopping, subscriptions, services), Everything else
3. Update Critical accounts first over 1–2 days before doing anything else
4. Set up email forwarding from your old address to your new one: in Gmail go to **Settings → See all settings → Forwarding and POP/IMAP → Add a forwarding address**
5. Keep forwarding active for at least 6 months - you'll catch accounts you missed

Download and archive your Gmail data before leaving

HIGH

takeout.google.com

Why it matters: Before closing your Gmail account, download everything - emails, contacts, calendar data. Your archive may contain important documents, receipts, legal notices, and other records you'll want to keep even if you don't actively use Gmail anymore.

Steps:

1. Go to **takeout.google.com** and sign in to your Google account
 2. Select **Mail** and **Contacts** (and **Calendar** if you use Google Calendar)
 3. Choose **.mbox** format for email - it's importable into most email clients
 4. Click **Next step → Create export**. Google will email you when the download is ready - this can take hours to days for large inboxes
 5. Store the archive in a secure location - encrypted external drive or ProtonDrive
-

Delete sensitive emails and attachments from your old inbox

HIGH

Gmail → Search → Delete

Why it matters: Even if you stop using Gmail, your data remains on Google's servers unless you delete it. Sensitive documents in your inbox - tax returns, medical records, legal correspondence, financial statements - can be subpoenaed from Google for years after you stopped reading them.

Steps:

1. Search for sensitive keywords: **tax**, **invoice**, **medical**, **insurance**, **passport**, **social security**, **bank statement**, **court**
 2. Download any important attachments locally before deleting
 3. Delete the emails, then go to **Trash** and **Empty trash** - deleted emails stay in trash for 30 days before permanent deletion
 4. Repeat this audit every few months while you're still transitioning
 5. When ready to fully leave: **Google Account** → **Data & privacy** → **Delete your Google Account**
-

EMAIL ADDRESS MASKING

Use relay addresses for website signups

HIGH

Firefox Relay, Apple Hide My Email, or SimpleLogin

Why it matters: Every website you give your real email address to becomes a potential breach vector. A relay address forwards email to your real inbox while keeping your actual address private. If you start receiving spam on a relay, you can disable it with one click - without changing your real address or updating any accounts.

Steps:

1. **Firefox Relay** (relay.firefox.com) - free tier gives 5 relay addresses. Premium (\$5/month) gives unlimited aliases and phone number masking
2. **Apple Hide My Email** - included with iCloud+ (\$1/month). Creates random relay addresses on the fly directly from Safari's autofill. Best option for iPhone users signing up for apps
3. **SimpleLogin** - open source, free tier with 15 aliases. Integrates natively with ProtonMail. Unlimited aliases on paid tier. Available at **simplelogin.io**
4. **Addy.io** (formerly AnonAddy) - open source, generous free tier, self-hostable. Good for high-volume alias usage at **addy.io**
5. Going forward: use a relay address for every website signup that isn't banking or government. Reserve your real address for people you know personally

Use disposable addresses for one-time verifications

MEDIUM

temp-mail.org or similar

Why it matters: Some websites require email verification just to view content or download a file. A disposable inbox receives the verification email without you giving up any real contact information - the inbox is temporary and you never have to check it again.

Steps:

1. **temp-mail.org** - generates a random temporary inbox. No signup required. Inbox expires after a short time
 2. **10minutemail.com** - gives you a 10-minute inbox for quick verifications
 3. **Mailinator.com** - creates public inboxes by name (e.g. anything@mailinator.com). Note these are public - don't use for anything sensitive, only for single-use confirmations
 4. Use these only for truly throwaway signups - for anything you might want to access again, use a persistent relay like SimpleLogin instead
-

Audit where your email address has been exposed

HIGH

haveibeenpwned.com

Why it matters: Your email address has almost certainly appeared in at least one data breach. Knowing which breaches it appeared in helps you identify which accounts to update first and which passwords to rotate immediately.

Steps:

1. Go to **haveibeenpwned.com** and enter each email address you use
 2. For every breach listed, check whether you still use that service - if so, update the password immediately using your password manager
 3. If your email appears in many breaches, it's widely distributed to spam lists - consider this a strong argument for moving to a new private address for important communications
 4. Enable breach notifications - HIBP can email you if your address appears in future breaches
-

EMAIL ACCOUNT SECURITY

Enable MFA on your email account - this is non-negotiable

CRITICAL

Your email provider → Settings → Security → Two-factor authentication

Why it matters: Your email account is the most important account to protect because it controls access to every other account via password reset. If an attacker gets into your email, they can take over your bank, your Apple or Google account, and everything else within minutes. MFA is the single most important thing you can do.

Steps:

1. ProtonMail: **Settings** → **Account and password** → **Two-factor authentication** → enable with an authenticator app
2. Gmail: **myaccount.google.com** → **Security** → **2-Step Verification** → add an authenticator app
3. Outlook: **account.microsoft.com** → **Security** → **Advanced security options** → enable authenticator app
4. Use an authenticator app (Proton Authenticator, Aegis, or Raivo) - not SMS. SMS is vulnerable to SIM swapping
5. Save your backup codes in your password manager vault immediately after enabling MFA

Use a strong unique password for your email account

CRITICAL

Your email provider → Settings → Account → Change password

Why it matters: Your email password should be the strongest password you have - at least 16 random characters. Because you should only ever need to type it into your password manager's autofill, there's no reason to compromise on complexity.

Steps:

1. Open your password manager and generate a new password - 20+ characters, mixed case, numbers, and symbols
 2. Update your email account password and save the new one in your password manager
 3. Verify MFA is still active after changing the password
 4. If you have recovery codes or a recovery email set, review those now too and make sure they're current
-

Revoke access for apps connected to your email

HIGH

Your email provider → Settings → Security → Connected apps or Third-party access

Why it matters: Many apps request permission to read your email - productivity tools, calendar apps, email clients, and services that claimed to 'import your contacts.' Each of these connections is a potential breach vector. Apps you no longer use retain read access indefinitely unless you revoke it.

Steps:

1. Gmail: **myaccount.google.com** → **Security** → **Third-party apps with account access** → review and remove any app you don't actively use or recognize
 2. Outlook: **account.microsoft.com** → **Privacy** → **Apps and services** → revoke unused apps
 3. ProtonMail: **Settings** → **Security and privacy** → **OAuth** → review connected apps
 4. Be especially cautious about anything with 'read all email' or 'send email on your behalf' permissions - these are extremely broad
-

INBOX HYGIENE

Unsubscribe from marketing emails and newsletters

MEDIUM

Email client → Unsubscribe link

Why it matters: Marketing emails contain tracking pixels - invisible 1x1 images that, when loaded, tell the sender your email address is active, your IP address, your device type, and when you opened the email. Unsubscribing eliminates the ongoing tracking and reduces your inbox's exposure surface.

Steps:

1. For legitimate companies (brands you've bought from, newsletters you signed up for): use the unsubscribe link at the bottom of the email
2. For spam or companies you don't recognize: do NOT click unsubscribe - it confirms your address is active. Mark as spam instead
3. **unroll.me** and **cleanfox.io** offer bulk unsubscribe - but read their privacy policies, as they analyze your inbox content to function
4. Consider disabling automatic image loading in your email client to block tracking pixels: in Gmail go to **Settings → See all settings → Images → Ask before displaying external images**

Disable tracking pixels in your email client

MEDIUM

Email client → Settings → Images

Why it matters: Email tracking pixels are used by marketers to know exactly when you opened an email, how many times, on what device, and from what location. This data feeds advertising profiles and is sold to data brokers. Blocking remote image loading completely eliminates this tracking vector.

Steps:

1. Gmail (web): **Settings → See all settings → General → Images** → select **Ask before displaying external images**
2. Apple Mail (iPhone): **Settings → Apps → Mail** → turn off **Load Remote Images**
3. Apple Mail (Mac): **Mail → Settings → Privacy** → enable **Protect Mail Activity** - this routes remote images through Apple's proxy to hide your IP
4. Outlook: **File → Options → Trust Center → Trust Center Settings → Automatic Download** → check **Don't download pictures automatically**
5. ProtonMail: blocks remote content by default - no action needed